

HO CHI MINH UNIVERSITY OF SCIENCE

FACULTY OF INFORMATION TECHNOLOGY

DATA SECURITY IN INFORMATION SYSTEMS



PROPOSAL

LECTURER:

PhD. Phạm Thị Bạch Huệ

STUDENT (GROUP 7):

Đỗ Quang Minh Triết - 23127131

Đinh Đại Vũ - 23127144

Lê Phạm Kiều Duyên - 23127184

Lê Trương Bảo Ngọc - 23127237

Nguyễn Đăng Phôn - 23127451

Contents

1	Introduction and Scope of Research	7
1.1	Alignment with the CIA Triad	7
1.2	Scope of Research	7
2	Classification and Architecture of Malicious Software	9
2.1	Overview	9
2.2	Classification	9
2.2.1	Viruses	9
2.2.2	Worms	10
2.2.3	Trojan Horses	12
2.2.4	Logic Bombs	13
2.2.5	Spyware	13
2.2.6	Adware	15
2.2.7	Botnets	16
2.2.8	Keystroke Loggers	17
2.2.9	Malicious Add-Ons (Browser Extensions)	17
3	Vulnerabilities and Malware Enablers	19
3.1	Active Content Vulnerabilities	19
3.2	Homepage Hijacking	19
3.3	Webpage Defacements	20
4	Attack Vectors	22
4.1	Social Engineering and Phishing	22
4.2	Spam-Based Attacks	22
4.3	Software Vulnerability Exploitation	22
4.4	Denial of Service (DoS/DDoS)	23
5	Anatomy of an Attack	24
5.1	What Motivates Attackers?	24
5.2	The Purpose of an Attack	25
5.3	Types of Attacks	26
5.3.1	Unstructured Attacks	26
5.3.2	Structured attacks	26
5.3.3	Direct Attacks	27
5.3.4	Indirect Attacks	27
5.4	Phases of an Attack	28
5.4.1	Reconnaissance and Probing	28
5.4.2	Access and Privilege Escalation	28
5.4.3	Covering Traces of the Attack	28
6	Case Studies	30
6.1	Historical Benchmarks: The Archetypes of Infection	30
6.1.1	The Morris Worm (1988): The Dawn of Automated Propagation . . .	30
6.1.2	ILOVEYOU (2000): The Blueprint of Social Engineering	31
6.2	The 2024–2025 Vietnam Ransomware Wave: Deep Dive Case Studies	32

6.2.1	The VNDirect Securities Incident (March 2024)	32
6.2.2	The PVOIL Ransomware Attack (April 2024)	33
6.2.3	Vietnam Post (June 2024)	34
6.3	Strategic Analysis and Defensive Postures	35
6.3.1	The Economic Calculus	35
6.3.2	Government Response	35
6.3.3	Recommendations for Resilience	35
7	Defense and Mitigation Strategies	37
7.1	General	37
7.2	Defense in Depth	37
7.2.1	Core Concept	37
7.2.2	Defense in Depth in the Context of Malware Protection	37
7.2.3	Typical Defense Layers	37
7.2.4	Relationship to Other Chapters	38
7.2.5	Practical Scenario	38
7.2.6	Summary	38
7.3	Patch Management	38
7.3.1	Concept and Role in Malware Defense	38
7.3.2	Why Patch Management Is Important	39
7.3.3	Patch Management in Defense and Mitigation	39
7.3.4	Relationship to Other Chapters	39
7.3.5	Common Patch Management Challenges	39
7.3.6	Case Study	39
7.3.7	Organizational Scenario	40
7.3.8	Summary	40
7.4	Backup Strategy – The 3-2-1 Rule	40
7.4.1	The Role of Backup in Malware Defense	40
7.4.2	What Is the 3-2-1 Rule?	40
7.4.3	Why Backup Is Especially Important Against Ransomware	41
7.4.4	Relationship to Other Chapters	41
7.4.5	Practical Scenarios	41
7.4.6	Significance of Backup Strategy	41
7.4.7	Summary	41
7.5	Incident Response Lifecycle	42
7.5.1	Why Incident Response Is Critical in Malware Defense	42
7.5.2	Incident and Incident Response	42
7.5.3	Stages of the Incident Response Lifecycle	42
7.5.4	Relationship to Other Chapters	42
7.5.5	Practical Scenario	43
7.5.6	Significance of Incident Response Lifecycle	43
7.6	User Awareness	43
7.6.1	Why User Awareness Is a Malware Defense Strategy	43
7.6.2	Core Components of User Awareness	43
7.6.3	User Awareness in the Context of Chapter 8	43
7.6.4	Relationship to Other Chapters	44
7.6.5	Practical Scenario	44

7.6.6	Role of User Awareness in Defense and Mitigation	44
7.6.7	Summary	44
7.7	Overall Summary	44
8	Future Trends in Malicious Software	45
8.1	AI-Powered and Autonomous Malware	45
8.2	Fileless Malware and "Living-off-the-Land" (LotL)	45
8.3	IoT Botnets and Critical Infrastructure Threats	45
8.4	Ransomware 3.0: The Triple Extortion Model	46
8.5	Supply Chain Attacks (Software Poisoning)	46
9	Conclusion	47
9.1	Final Summary of Key Lessons	47
9.2	The Reality in Vietnam	47
9.3	Final Words	47

List of Figures

List of Tables

1	List of group members	6
2	Task assignment and completion status	6
3	Key statistical indicators of the 2024–2025 cyber threat landscape	36

Group Members

No.	Full Name	Student ID	Email	Contribution
1	Đỗ Quang Minh Triết	23127131	dqmtriet23@clc.fitus.edu.vn	20%
2	Đinh Đại Vũ	23127144	ddvu23@clc.fitus.edu.vn	20%
3	Lê Phạm Kiều Duyên	23127184	lpkduyen23@clc.fitus.edu.vn	20%
4	Lê Trương Bảo Ngọc	23127237	ltbngoc23@clc.fitus.edu.vn	20%
5	Nguyễn Đăng Phôn	23127451	ndphon23@clc.fitus.edu.vn	20%

Table 1: List of group members

Task Assignment

No.	Task	Responsible	Completion
1	Introduction and Scope of Research	Lê Phạm Kiều Duyên	
2	Classification and Architecture of Malicious Software	Nguyễn Đăng Phôn	
3	Vulnerabilities and Malware Enablers	Nguyễn Đăng Phôn	
4	Attack Vectors	Lê Trương Bảo Ngọc	
5	Anatomy of an Attack	Lê Trương Bảo Ngọc	
6	Case Studies	Đinh Đại Vũ	
7	Defense and Mitigation Strategies	Đỗ Quang Minh Triết	
8	Future trends	Lê Phạm Kiều Duyên	
9	Conclusion	Lê Phạm Kiều Duyên	

Table 2: Task assignment and completion status

1 Introduction and Scope of Research

Malicious software, commonly referred to as "malware," represents one of the most persistent and evolving threats in the digital landscape. As defined in Chapter 8, malware is any program or set of instructions designed to perform unauthorized operations on a system without the user's consent [1]. From the early days of "sneakernet" transmissions via floppy disks to the modern era of sophisticated Advanced Persistent Threats (APTs), the architecture and operational methods of malware have shifted from mere academic curiosity to a multi-billion dollar criminal industry.

1.1 Alignment with the CIA Triad

To fully comprehend the danger posed by malware, its impact must be examined through the lens of the CIA Triad (Confidentiality, Integrity, and Availability), as introduced in Chapter 1:

- **Confidentiality:** Malware such as *Spyware*, *Keyloggers*, and *Trojan Horses* are engineered to covertly exfiltrate sensitive data, including login credentials and intellectual property, directly violating the principle of confidentiality.
- **Integrity:** *Viruses* and *Worms* often modify system files or inject malicious code into legitimate applications. This unauthorized alteration compromises the integrity of the data and the underlying operating system [1].
- **Availability:** *Ransomware*—the most prevalent threat today—encrypts critical data to extort victims, while *Botnets* launch Distributed Denial of Service (DDoS) attacks. Both actions render systems unusable, thereby annihilating service availability.

1.2 Scope of Research

This report covering the lifecycle of malicious software from inception to mitigation. The scope of this research is organized into the following key domains:

1. **Classification and Architecture:** We investigate the internal behavior and characteristics of diverse malware types, including self-replicating agents (*Viruses*, *Worms*), deceptive software (*Trojan Horses*, *Logic Bombs*), and persistent monitoring tools (*Spyware*, *Adware*, *Keystroke Loggers*, and *Malicious Browser Extensions*).
2. **Vulnerabilities and Enablers:** A focus on the conditions that facilitate malware execution, specifically *Active Content Vulnerabilities* (JavaScript, ActiveX), *Homepage Hijacking*, and the exploitation of web application weaknesses.
3. **Attack Vectors and Methodology:** We analyze how attackers approach their targets using *Social Engineering*, *Spam-based attacks*, and *Software Vulnerability Exploitation*. This includes a deep dive into *DoS/DDoS* techniques such as SYN Floods and Smurf attacks.
4. **The Cyber Kill Chain:** An anatomical breakdown of a modern attack, mapping the phases from initial reconnaissance and probing to covering tracks and maintaining access using *Remote Access Tools (RATs)*.

5. **Empirical Analysis (Case Studies):** A comparison of historical malware benchmarks against contemporary threats, specifically focusing on the *2024-2025 Vietnam Ransomware Wave* affecting critical financial and energy sectors.
6. **Defense and Mitigation:** An evaluation of the *Defense in Depth* strategy, encompassing *Patch Management*, the *3-2-1 Backup Strategy*, and the *Incident Response Lifecycle* to ensure organizational resilience.

2 Classification and Architecture of Malicious Software

2.1 Overview

Malware (*malicious software*) refers to programs that run on a computer and perform actions the user does not intend. Attackers can cause harm in several ways:

- Gaining administrative control of a system to issue harmful commands.
- Establishing *command-and-control* (C2) channels that allow attackers to send remote commands executed by the infected system.
- Propagating through various attack vectors, including removable media (e.g., USB drives or malicious USB cables) and network-based channels such as the Internet.
- Using legitimate remote administration tools to scan for and exploit system vulnerabilities.

2.2 Classification

Most computer users refer to any malicious code as a ***virus***; however, in reality, there are several types of viruses as well as many other forms of malicious code. Each of these has unique characteristics and architectures, and therefore requires different approaches to defend against them.

2.2.1 Viruses

Definition A computer virus is a software program that attaches itself to or replicates by inserting its code into another executable program on a computer. Its core purpose is to trick the system into executing actions that were not intended by the original program's developer.

Characteristics

- **Dependency:** A virus typically requires user interaction, such as executing an infected file, to activate and infect a host program.
- **Propagation Mechanism:** It spreads by attaching itself to executable files and replicating.
- **Payload Behavior:** The virus may carry a payload that is destructive, hidden, or non-malicious.
- **Stealth and Persistence:** Some viruses hide their payload or install backdoors, enabling long-term undetected access.

Propagation Mechanisms

- **System infectors:** They target system boot functions, typically the Master Boot Record (MBR), to gain control before protective mechanisms are loaded.
- **File infectors:** Attach to executable files to replicate and spread. They primarily target Windows systems and, in some cases, may also affect mobile and IoT devices. These

viruses control program execution to replicate and may deliver a payload. Companion viruses exploit file extension priority to execute before legitimate programs.

- **Data/Macro infectors:** Infect document files containing macros, allowing malware to spread when files are opened or shared. They are easy to create, cross-platform, and commonly delivered via malicious email attachments or shared templates.

Other Virus Classifications Most viruses propagate by copying exact replicas of themselves to infected files or systems, creating predictable signatures that antivirus software can detect. However, some viruses employ advanced techniques to evade detection, including:

- Polymorphic viruses
- Stealth viruses
- Slow viruses
- Retro viruses
- Cross-platform viruses
- Multipartite viruses

Examples Examples of historically significant computer viruses include: [2]

- ILOVEYOU (2000)
- Klez (2001)
- Nimda (2001)
- Sasser (2004)
- Conficker (2008)
- Shamoon (2012 and 2016)

Detection Virus infections may be detected through reduced system performance, abnormal disk or memory usage, frequent system crashes or errors, unexpected antivirus alerts, and unusual file or application behavior.

2.2.2 Worms

Definition Worms are self-contained malware programs that propagate automatically from one host to another using network communication protocols, without requiring a host program or user interaction.

Characteristics

- Do not attach to executable files.
- Operate independently as standalone programs.

- Spread rapidly across networks.
- Consist of components running on multiple systems and communicating over a network.

Propagation Mechanisms

- **Independence and autonomous operation:** Worms are self-contained programs capable of self-replication and network-based propagation without attaching themselves to a host program, unlike computer viruses.
- **No human interaction required:** The propagation process occurs fully automatically and does not require any user action or interaction to initiate infection.
- **Scanning and vulnerability exploitation:** Worms actively scan network-connected systems to identify and exploit specific software or operating system vulnerabilities, such as buffer overflow flaws or remote code execution vulnerabilities.
- **Email-based propagation:** After compromising a host, worms may harvest email addresses from the system and automatically send copies of themselves to other targets via the Simple Mail Transfer Protocol (SMTP) or the host's email infrastructure.
- **Multiple infection vectors:** In addition to email, worms can spread rapidly through shared network drives, misconfigured services, or compromised websites.
- **Termination conditions:** Propagation continues until the worm is detected and contained by security mechanisms, or until security patches are applied to eliminate the exploited vulnerabilities.

Examples Notable worms include:

- Morris Worm
- Conficker
- Stuxnet
- WannaCry
- Sobig.F
- Blaster
- Linux worms such as L10n, Badbunny, and Darlloz

Detection Worm infections may be detected through:

- Unexplained increases in bandwidth consumption.
- High volumes of inbound and outbound email or other network traffic during normal activity periods.
- Unexplained decreases in available disk space.
- Unusual increases in average message size or the volume of attachments.

- Unexpected Simple Mail Transfer Protocol (SMTP) or Post Office Protocol 3 (POP3) daemon responses.
- Sudden increases in user response times across the network or sudden congestion at chokepoints near server clusters.

2.2.3 Trojan Horses

Definition Trojan horses represent one of the most prevalent and diverse categories of malware. A Trojan horse is any program that masquerades as a useful or legitimate application while hiding its malicious intent. Trojans typically encourage users to download and execute the program voluntarily.

Characteristics

- **Information theft:** Trojan horses are often designed to steal sensitive information such as passwords, banking credentials, and personal data stored on the victim's system.
- **Remote access:** A Trojan may grant attackers remote access, allowing them to control the infected system without the user's knowledge or consent.
- **Data deletion or corruption:** Some Trojans delete or corrupt files, leading to data loss or system instability.

Propagation Mechanisms Trojan horses are distributed through multiple delivery methods:

- **Email attachments:** Trojans are often attached to malicious or fake emails. When users download and open the attachment, the Trojan installs itself and may execute automatically on system startup or file access.
- **Social engineering:** Attackers trick users into installing Trojans through malicious links, pop-up advertisements, fake software updates, or deceptive banner ads.
- **Infected devices:** Once a device is compromised, the Trojan may spread to other systems via networks or removable media. Infected machines can be remotely controlled and used as part of a botnet.

Examples Common types of Trojan horses include:

- Backdoor Trojan
- Exploit Trojan
- Banker Trojan
- DDoS Trojan
- Downloader Trojan

Detection Trojan infections may be detected through:

- Unrecognized or suspicious new processes running on the system.
- Startup messages indicating unexpected software installation or registry updates.
- Applications becoming unresponsive to normal commands.
- Unusual redirection of web requests to unknown or malicious websites.
- Unexpected remote logon prompts at unusual times or unfamiliar logon interfaces.
- Sudden termination or failure of antivirus or personal firewall software.

2.2.4 Logic Bombs

Definition A logic bomb is a program that executes a malicious function when specific conditions are met or at a predetermined time.

Characteristics

- Malicious tasks may cause immediate damage or initiate a sequence of events that results in damage over an extended period.
- Logic bombs are often associated with insider threats, as insiders typically possess detailed knowledge of organizational systems.
- Remain dormant while waiting for specific conditions or a triggering time.

Activation Mechanism

- Logic bombs are usually embedded and concealed within legitimate software by individuals who have authorized access to the system.

Examples

- A common example involves a programmer embedding a logic bomb into company software that automatically deletes critical files or causes system damage if the programmer is terminated.

Detection

- Logic bombs are difficult to detect because they are deliberately designed to remain hidden until activation.
- Designers often understand organizational security controls and place logic bombs in locations that are unlikely to attract attention.

2.2.5 Spyware

Definition Spyware is any unsolicited background process that installs itself on a user's computer without the user's knowledge or consent. It is designed to collect information about the user's browsing habits, website activities, and potentially sensitive personal data.

Characteristics

- **Data collection:** Gathers sensitive personal information such as account credentials, balances, and other private data for identity theft or fraud.
- **Keystroke logging:** Records all keystrokes, including passwords, emails, and chat messages.
- **Activity tracking:** Monitors online behavior such as visited websites, search queries, and social media activity to analyze patterns or deliver targeted advertisements.
- **Screen capturing:** Takes screenshots of the device screen, potentially exposing confidential information.
- **Remote control:** Some advanced spyware variants include remote access capabilities.

Distribution Mechanisms

- **Phishing:** Spyware enters the system when users click malicious links or download infected attachments.
- **Spoofing:** Attackers disguise malicious emails as legitimate messages to trick users into installing spyware.
- **Freeware/Shareware bundling:** Spyware is bundled with free or shared software during installation.
- **Misleading software:** Fake optimization or utility programs secretly install spyware to steal confidential information.

Examples

- **Pegasus:** A highly sophisticated and targeted spyware platform primarily used for surveillance by state-level actors.

Detection

- Slow system performance, frequent freezing, or unexpected crashes due to excessive resource consumption.
- Unusual network activity, such as abnormally high traffic or excessive outbound connections.
- Frequent and unexpected pop-up windows or advertisements.
- Unwanted changes to browser settings, including homepage, search engine, or bookmarks.
- Appearance of unfamiliar or suspicious programs or running processes.

Spyware detection typically relies on endpoint protection platforms, behavioral analysis, network traffic monitoring, and specialized anti-spyware tools.

2.2.6 Adware

Definition Adware is a type of software designed to automatically display or download advertising material, such as pop-up windows and banner advertisements, often without the user's consent.

Characteristics

- **Disruption:** Adware triggers intrusive behaviors such as pop-up windows and banner advertisements when users visit certain websites.
- **Productivity impact:** Adware negatively affects user productivity and overall system performance.
- **Privacy risk:** Adware may track user behavior to deliver targeted advertisements, potentially violating user privacy.

Propagation Mechanisms

- Adware is commonly bundled with freeware or shareware and is unknowingly installed by users during software installation.
- It may also be distributed through deceptive pop-up windows or misleading download prompts.

Examples

- Web banners
- Pop-up advertisements
- Browser toolbars
- In-text advertisements injected into webpages

Prevention

- Download software only from official websites or reputable sources.
- Read license agreements carefully and use custom installation options to decline bundled programs.
- Regularly update the operating system and applications to patch security vulnerabilities.
- Use reliable security software for additional protection.
- Avoid clicking suspicious links or downloading attachments from unknown sources.
- Be cautious of websites that trigger unexpected downloads.
- Stay informed about emerging adware threats and share knowledge to promote safer online practices.

2.2.7 Botnets

Definition Botnets (short for robotically controlled networks) are networks of compromised computers that are remotely controlled by an attacker. The individual who manages and issues commands to the botnet is commonly referred to as a *bot-herder* or controller. In simple terms, a botnet is a collection of Internet-connected devices coordinated to perform malicious activities.

Characteristics

- **Remote control:** Early botnets primarily used Internet Relay Chat (IRC) channels for communication, whereas modern botnets increasingly rely on HTTP/HTTPS, peer-to-peer architectures, or cloud-based services to evade detection.
- **Use of agents:** Attackers install software agents on compromised systems to execute commands and perform malicious tasks.
- **High computational power:** Botnets can generate enormous computing power; in some cases, their combined performance has rivaled that of the world's most powerful supercomputers.
- **Resilience:** Botnets are difficult to dismantle because they are distributed across a large number of geographically dispersed systems.

Propagation Mechanisms

- **Exploiting vulnerabilities:** Attackers scan for systems with security vulnerabilities and install botnet control agents upon successful compromise.
- **Self-replication via malware:** Many modern viruses and worms contain components that convert infected machines into botnet nodes.
- **Spam distribution:** Infected machines (often called *zombies*) are used to send spam emails containing malware to propagate the botnet further.

Examples

- **Storm botnet:** In 2007, it was recorded as one of the most powerful computer networks in the world at that time.
- **Attacks on U.S. banks (2012–2013):** Botnets were used to carry out large-scale attacks against major U.S. financial institutions and infrastructure.

Detection

- Detecting botnets is challenging because they are distributed across numerous personal computers, servers, and devices.
- Tracing and identifying the bot-herder is difficult, as control may be exercised from locations far removed from the infected systems.
- Securing all computing devices, including Internet of Things (IoT) devices, is essential to prevent their exploitation as botnet participants.

2.2.8 Keystroke Loggers

Definition A keystroke logger is a type of software or hardware monitoring tool capable of recording every keystroke a user makes on a keyboard into a log file. The recorded data may be stored locally for later retrieval or transmitted over a network to a designated recipient.

Characteristics

- **Monitoring tool:** Keystroke loggers function as tracking tools and may be embedded within spyware to steal passwords and personal information.
- **Dual-use nature:** Keystroke loggers can be used legitimately by organizations to monitor employee productivity, but are frequently abused by cybercriminals for malicious purposes.
- **Stealthy operation:** Hardware-based keystroke loggers are typically small and designed to be hidden in inconspicuous locations, such as behind a computer or within cable connections.

Propagation Mechanisms

- **Physical form:** Hardware keystroke loggers require the attacker to physically connect an intermediary device between the keyboard and the computer's input port.
- **Software form:** Software-based keystroke loggers are commonly distributed as Trojan malware via malicious URLs, email attachments (e.g., PDF or ZIP files), or stealthily installed as part of a rootkit after system compromise.

Examples

- **Hardware:** Plug-in devices approximately the size of a battery that attach to USB or legacy keyboard ports and store keystroke data internally.
- **Software:** Malicious programs that record keystrokes and periodically transmit the collected data to attackers over the Internet without the user's knowledge.

Detection

- **Physical inspection:** Manually inspect keyboard and computer ports for unfamiliar or unauthorized devices.
- **Security software:** Use antivirus and anti-malware tools to scan for suspicious processes or keystroke-recording software.
- **System monitoring:** Monitor system behavior, review activity logs, and identify unknown or suspicious network connections.

2.2.9 Malicious Add-Ons (Browser Extensions)

Definition Browser add-ons (also known as extensions) are companion programs that operate alongside a web browser to extend its functionality, such as integrating news feeds

or weather alerts. Malicious add-ons are browser extensions that contain embedded malware.

Characteristics

- **Reduced security:** Malicious add-ons lower the overall security level of the web browser and the underlying computer system.
- **Unauthorized actions:** Once installed, these extensions can perform various malicious activities using the browser's privileges.
- **Disguised nature:** They often appear to be legitimate or useful tools while secretly carrying out harmful actions.

Propagation Mechanisms

- **Voluntary but uncontrolled installation:** Users may install malicious add-ons unknowingly, believing them to be legitimate extensions.
- **Untrusted sources:** These add-ons are commonly distributed through unreliable websites or unknown extension providers.

Examples

- Malicious browser toolbars designed to track user activity or display unauthorized advertisements.
- Deceptive extensions that claim to offer features such as news updates, weather information, or system optimization but instead install malware.

Detection

- Exercise caution when installing browser extensions and use only trusted sources.
- Regularly review installed add-ons to ensure all extensions are recognized and necessary.

3 Vulnerabilities and Malware Enablers

To better understand how malware operates, it is crucial to examine the methods and techniques used by attackers. These techniques exploit system vulnerabilities, allowing malicious code to infiltrate systems and cause harm. In this section, we explore common attack methods and analyze how malware targets computer systems and networks.

3.1 Active Content Vulnerabilities

Definition Active content refers to components, primarily on web pages, that provide functionality for interacting with users. This includes any dynamic object that performs an action when a user opens a web page. Common technologies used to implement active content include ActiveX, Java, JavaScript, VBScript, scripts, browser plug-ins, and PDF files.

How It Works Active content is considered a form of mobile code because it can execute across different computing platforms. When a user visits a website, the web browser downloads this code and executes it within the browser's context, using the user's credentials and privileges. Once downloaded, the mobile code may gain access to local system resources, including the computer's hard drive.

Attack Techniques Attackers exploit weaknesses in active content mechanisms to execute malicious code. A common attack technique is *Cross-Site Scripting (XSS)*, which allows attackers to inject client-side scripts into web pages viewed by users. When a user accesses such a page, the browser automatically executes the malicious script, often bypassing access control mechanisms.

Impact Malicious active content can cause severe consequences, such as flooding the desktop with icons representing malware-infected files. These files may continue to replicate and generate additional copies of the malicious code. The overall impact depends on the sensitivity of the compromised system and the data it contains.

Prevention

- **Browser configuration:** Configure browser security settings to block or warn users before executing scripts or dynamic content.
- **Content filtering:** Implement network-level filtering to analyze traffic, identify dynamic code components (e.g., Java or ActiveX), and disable script processing within web browsers.
- **Pop-up blocking:** Require users to enable pop-up blockers to prevent automatic pop-up windows and reduce the risk of unintentional malware execution.

3.2 Homepage Hijacking

Definition Homepage hijacking is a type of attack that alters a web browser's homepage configuration so that it redirects users to a website chosen by the attacker.

How It Works This attack resets the browser’s homepage settings, typically without the user’s permission. Attackers may install hidden programs that preserve the malicious configuration even when the user attempts to restore the original homepage.

Attack Techniques Attackers commonly use the following methods to perform homepage hijacking:

- **Exploiting browser vulnerabilities:** Taking advantage of security flaws in web browsers or active content components to modify homepage settings.
- **Social engineering:** Tricking users into performing actions that appear beneficial but actually initiate malware execution (e.g., fake buttons claiming to remove infections).
- **Browser Helper Objects (BHOs):** Installing Trojan programs in the form of BHOs that register themselves in the system startup process and execute automatically each time the system boots.

Impact

- The browser repeatedly opens the attacker’s website instead of the user’s preferred homepage.
- Persistent annoyance and loss of control, as hijacking programs continuously reset the homepage until the malware is fully removed.

Prevention

- Exercise caution when interacting with websites, especially when clicking buttons or links from unknown or untrusted sources.
- Review system startup processes and remove suspicious or unauthorized entries.
- Fully identify and eliminate malicious programs or Browser Helper Objects to prevent repeated homepage changes.

3.3 Webpage Defacements

Definition Webpage defacement (also known as web graffiti) is the act of gaining unauthorized access to a web server and altering the content of the index page or other web pages hosted on that server.

How It Works Attackers typically target publicly accessible web servers on the Internet. The attack process involves identifying and exploiting known security vulnerabilities to gain administrative or elevated access. Once control is obtained, the attackers replace legitimate web pages with modified or malicious versions.

Attack Techniques

- **Exploiting software vulnerabilities:** Attackers exploit security flaws in the server’s operating system or service applications (e.g., vulnerabilities in web servers) to gain unauthorized access.

- **Installing backdoors:** Some malware installs Trojan backdoors after infection, enabling attackers to remotely access the server and alter website content at any time.
- **Using automated tools:** Script kiddies and organized hacker groups often use automated vulnerability-scanning tools to identify poorly secured websites before launching attacks.

Impact

- **Defacement and nuisance:** Webpage defacement is often considered a form of digital graffiti that disrupts normal website operations.
- **Reputational damage:** Defaced websites may display offensive messages or inappropriate content, damaging organizational credibility and user trust.
- **Serious security risks:** Attackers may embed malicious active content, such as viruses or Trojan programs, exposing visitors to further compromise.

Prevention

- **Software updates:** Keep web server operating systems and applications up to date with the latest security patches.
- **Disabling unnecessary services:** Turn off unused services and close unneeded network ports to reduce attack surfaces.
- **Network defense layers:** Use proxy servers or bastion hosts to protect critical services and filter malicious traffic.
- **Monitoring and testing:** Conduct regular vulnerability assessments and penetration testing to identify and remediate weaknesses proactively.

4 Attack Vectors

Attack vectors refer to the methods or pathways used by attackers to gain unauthorised access to systems, networks, or data. Understanding attack vectors is critical for analysing how attacks are initiated and for designing effective defensive strategies. Common attack vectors exploit human behaviour, technical vulnerabilities, or weaknesses in system availability.

4.1 Social Engineering and Phishing

Social engineering attacks exploit human psychology rather than technical vulnerabilities to gain access to sensitive information or systems. Attackers manipulate victims into revealing credentials, downloading malicious files, or performing actions that compromise security. Phishing is one of the most prevalent forms of social engineering and typically involves deceptive emails, messages, or websites that impersonate legitimate entities. These attacks often create a sense of urgency or authority to pressure victims into compliance. Due to their reliance on human error, social engineering and phishing attacks remain highly effective despite advancements in technical security controls.

Real-world example: The Twilio Breach (2022). Attackers sent SMS messages to Twilio employees pretending to be the IT department, urging them to update their passwords or review new schedules. The texts contained the employee’s actual names and legit-looking URLs leading to a fake Twilio sign-in page. Some workers tried to log in, revealing their user credentials [3].

4.2 Spam-Based Attacks

Spam-based attacks involve the mass distribution of unsolicited messages containing malicious links, attachments, or payloads. Unlike targeted phishing campaigns, spam-based attacks are typically indiscriminate and aim to infect a large number of systems with minimal effort. These attacks are commonly used to spread malware, ransomware, or trojans and often rely on at least some recipients interacting with the malicious content. Spam-based attacks are frequently used as an initial delivery mechanism in larger attack campaigns.

Real-world example: The Emotet Botnet. Before its disruption, Emotet was the world’s most dangerous malware distributor, largely spreading via massive spam campaigns containing malicious Word documents (fake invoices or shipping receipts). It served as the primary delivery mechanism for other ransomware like Ryuk [4].

4.3 Software Vulnerability Exploitation

Software vulnerability exploitation occurs when attackers take advantage of flaws in operating systems, applications, or network services. These vulnerabilities may arise from coding errors, misconfigurations, or outdated software lacking security patches. Attackers often use automated tools or exploit frameworks to identify and exploit known vulnerabilities, although advanced attackers may leverage zero-day vulnerabilities that have not yet been publicly disclosed. Successful exploitation can lead to unauthorized access, privilege escalation, or remote code execution.

Real-world example: Log4Shell (CVE-2021-44228). Discovered in late 2021, this critical vulnerability affected Apache Log4j, a widely used logging library in Java applications. At the peak of Log4Shell activity, Check Point observed more than 100 attacks every minute, affecting more than 40% of all business networks globally [5] [6].

4.4 Denial of Service (DoS/DDoS)

Denial of Service (DoS) and Distributed Denial of Service (DDoS) attacks aim to disrupt the availability of systems or services by overwhelming them with excessive traffic or resource requests. In a DDoS attack, multiple compromised systems, often part of a botnet, are used to amplify the attack's impact. These attacks do not necessarily involve data theft but can cause significant operational and financial damage by rendering services inaccessible to legitimate users.

Real-world example: The Dyn Cyberattack (2016). The Mirai Botnet, composed of insecure IoT devices (cameras, routers), launched a massive DDoS attack against Dyn (a DNS provider). This attack successfully took down major platforms like Twitter, Netflix, and Reddit for hours, highlighting the power of volumetric attacks [7].

[8]

5 Anatomy of an Attack

In order to develop practical and efficacious countermeasures, it is essential that the objectives, the key targets, and the characteristics of an attack must be known.

5.1 What Motivates Attackers?

Contrary to popular belief, today's attackers are not merely socially marginalised individuals driven by thrill-seeking impulses or amateur experimentation. There is much more complexity to the reasons behind attacks, namely:

- Monetary gain:
 - Objective: To generate illicit profit through theft or extortion.
 - A real-life example: Hieu Ngo Minh, also known as Hieu PC, a Vietnamese hacker who was formerly involved in identity-theft operations, stole and sold large volumes of personally identifiable information, including millions of U.S. Social Security numbers. His activities generated substantial illegal profits and caused significant financial damage. In his 20s, he made roughly \$100,000 just by hacking and selling [9]. He later admitted that he was motivated by financial pressure and his own greed.

[10]

- Attention-seeking behaviours or notoriety gain:
 - Objective: Mainly to achieve fame and recognition in cyberspace.
 - A real-life example: The hacker group LulzSec carried out a series of high-profile cyberattacks in 2011 targeting organisations such as Sony, PBS, and Fox. Rather than focusing on financial profit, the group aimed to embarrass companies and demonstrate security flaws to gain notoriety. Their attacks exposed millions of users' data and generated widespread media coverage.

[11]

- The imposition of beliefs or systems on others:
 - Objective: To promote political, social, or ideological agendas by influencing public opinion.
 - A real-life example: Anonymous is an international collective, a group of hacktivists that distorts the line between activism and cybercrime. Over the years, Anonymous has executed campaigns targeting a variety of organisations such as PayPal and Sony, in response to perceived injustices or threats to free speech. Significant campaigns include Project Chanology, Operation Payback, and more recent actions in support of the Black Lives Matter movement following George Floyd's death.

[12] [13]

- Personal anger:
 - Objective: To exact revenge due to personal conflicts.

- A real-life example: In 2000, the Maroochy Water Services attack in Australia involved a former employee, Vitek Boden, who used his insider knowledge of SCADA systems to manipulate sewage infrastructure. He left his job after a rocky relationship with his employer and was denied a job position after applying for the Maroochy Shire Council. His actions released hundreds of thousands of litres of sewage into local waterways and thus causing pollution.

[14]

- Nation-state cyberwarfare:
 - Objective: To achieve strategic geopolitical or military advantages by disrupting critical infrastructure or intelligence capabilities.
 - A real-life example: Stuxnet (2010) is widely considered the first digital weapon used for cyberwarfare. It was a sophisticated computer worm, allegedly developed by the United States and Israel, designed specifically to target Iran’s nuclear program. It specifically infected computers controlling the centrifuges at the Natanz nuclear facility, causing them to operate irregularly and degrade faster than normal, thus hindering uranium enrichment efforts.

[15] [16]

- Economic espionage:
 - Objective: To obtain intellectual property, trade secrets, or sensitive business information for economic or technological advantage.
 - A real-life example: In 2026, a former Google engineer, Linwei Ding, was convicted of economic espionage after stealing more than 2,000 confidential AI-related documents while employed at the company. Prosecutors stated that the stolen information contained sensitive trade secrets that could benefit two Chinese companies he was secretly working for.

[17] [18]

5.2 The Purpose of an Attack

There are four primary purposes of an attack:

- Denial of availability: To prevent legitimate users from accessing a system or data.
- Data modification: To modify, delete, or overwrite files on a local or network drive. Alternatively, the goals might be the modification of system settings or browser security settings
- Data export (exfiltration): To steal information and transfer it to external destination
- Launch point: To target a device as a launch point to infect and target other devices as part of a greater attack plan.

5.3 Types of Attacks

5.3.1 Unstructured Attacks

- Characteristics:
 - Frequently executed by moderately skilled attackers targeting network resources
 - Limited planning
 - Utilising existing scripts, toolkits, or automated exploits available on the Internet to scan for known vulnerabilities.
- Motivation: To achieve personal gratification, such as the thrill of overcoming security measures, gaining illegal access, or earning recognition within hacker communities.
- Target: Publicly accessible network resources, vulnerable websites, or systems discovered through automated scanning for known weaknesses.
- Impact: Unstructured attacks may lead to website defacement, accidental system crashes, data exposure, or the discovery of unintended vulnerabilities that can later be exploited through more organised attacks.
- A case in point: The "Mafiaboy" DDoS Attacks (2000), Michael Calce, a 15-year-old Canadian high school student known as "Mafiaboy," launched a series of massive Denial-of-Service attacks against major industry giants, including Yahoo!, CNN, eBay, and Amazon.

[19]

5.3.2 Structured attacks

- Characteristics:
 - Carefully planned and methodical in nature.
 - Typically carried out by highly skilled attackers or organised groups.
 - Involve sophisticated hacking techniques to identify, probe, penetrate, and carry out malicious activities.
- Motivation: Financial gain, political or ideological objectives, retaliation, or strategic advantage.
- Target: Specific and high-value targets, such as government agencies, large enterprises, critical infrastructure, or individuals with privileged access.
- Impact: Can lead to severe and long-term consequences, including large-scale data breaches, service disruption, financial losses, and compromise of critical systems.
- A case in point: Carried out by a highly sophisticated sponsored group (identified as Nobelium/APT29), the attackers compromised the build system of the SolarWinds Orion platform. By injecting the "Sunburst" backdoor into legitimate software updates, they successfully infiltrated over 18,000 organisations, including high-value targets such

as government departments, namely Homeland Security, State, Commerce and Treasury were affected. The attack remained undetected for months, which is the manifestation of the extreme planning and patience characteristic of a typical structured threat.

[20] [21]

5.3.3 Direct Attacks

- Characteristics:
 - Executed in real time, where attackers interact directly with the target system.
 - Might involve remote logon attempts, password guessing, session hijacking, or exploitation of known software vulnerabilities.
 - Can be either unstructured or structured, depending on the attacker's skill level and planning.
- Motivation: Varies from personal gratification and experimentation to financial gain, disruption, or preparation for larger coordinated attacks.
- Target: Specific organisations, individual systems, or classes of targets such as networks running particular hardware, operating systems, or vulnerable services.
- Impact: Direct attacks may result in website defacement, unauthorised access, malware implantation, or the compromise of internal network resources, potentially enabling further attacks.
- A case in point: The MOVEit Transfer exploit (2023), where attackers (CL0P) exploited a vulnerability in file-transfer software to directly access sensitive data from organisations worldwide. This zero-day vulnerability enabled attackers to exploit public-facing servers via SQL injection, facilitating unauthorised file theft.

[22]

5.3.4 Indirect Attacks

- Characteristics:
 - Executed by preprogrammed malicious code such as worms or viruses.
 - Propagate automatically and indiscriminately without direct interaction from the attacker.
 - Often exploit specific software vulnerabilities, but spread widely across networks and systems.
- Motivation: To achieve large-scale disruption, widespread infection, or to amplify the impact of an attack with minimal ongoing attacker involvement.
- Target: Broad and non-specific targets, including any vulnerable systems or networks.
- Impact: Can lead to rapid and widespread system compromise, network congestion, denial of service, data loss, and increased recovery costs for affected organisations.

- A case in point: The WannaCry ransomware worm (2017), which exploited the Eternal-Blue vulnerability in Microsoft Windows systems. Once released, the malware propagated automatically across networks without requiring continuous attacker interaction, encrypting victims' files and demanding ransom payments in cryptocurrency. The attack rapidly spread across more than 150 countries, disrupting hospitals, transportation services, and businesses worldwide.

[23] [24]

5.4 Phases of an Attack

5.4.1 Reconnaissance and Probing

- Characteristics:
 - The most important phase.
 - The initial information-gathering phase where attackers identify potential entry points and vulnerabilities.
 - Involves techniques such as DNS lookups, ICMP probing, SNMP queries, port scanning, and vulnerability assessment tools.
 - May also include collecting publicly available information about organisations, infrastructure, and personnel.
- Objective: To build a detailed profile of the target environment, including operating systems, open ports, network topology, and exposed services.
- Impact: Even without direct intrusion, reconnaissance activities can expose sensitive operational details and increase the likelihood of a successful attack.

5.4.2 Access and Privilege Escalation

- Characteristics:
 - Attackers attempt to gain unauthorised entry through exploits, stolen credentials, rogue wireless access points, or legacy remote-access services.
 - Techniques include password capturing, cracking, and deploying Remote Access Trojans (RATs) to maintain persistence.
 - Privilege escalation is often performed to obtain administrative-level control.
- Objective: To establish a stable foothold within the target system and expand control across the network.
- Impact: Successful access may lead to malware installation, lateral movement, data theft, or long-term system compromise.

5.4.3 Covering Traces of the Attack

- Characteristics:

- Attackers attempt to erase or modify logs, remove malicious files, and restore systems to a preattack state to avoid detection.
 - May involve disabling monitoring tools or bypassing auditing mechanisms.
- Objective: To conceal attacker activity and prolong unauthorised access.
- Impact: Makes incident response and forensic investigation significantly more difficult, increasing organisational risk.

[8]

6 Case Studies

To fully comprehend the sophistication of the cyber-sieges witnessed in Vietnam during 2024, one must first deconstruct the progenitors of modern malicious software. The history of malware is not merely a chronicle of code but a study in the exploitation of trust—both technical and human. The following analyses serve as the “Historical Benchmarks” that defined the attack vectors still exploited by contemporary threat actors, followed by a forensic examination of the 2024–2025 Vietnam Ransomware Wave.

6.1 Historical Benchmarks: The Archetypes of Infection

6.1.1 The Morris Worm (1988): The Dawn of Automated Propagation

On the evening of November 2, 1988, the nascent infrastructure of the internet—then known as the ARPANET and consisting of approximately 60,000 nodes—experienced its first cataclysmic denial-of-service event [25]. The “Morris Worm,” authored by Robert Tappan Morris, a graduate student at Cornell University, was unleashed from a terminal at the Massachusetts Institute of Technology (MIT) in an attempt to obscure its origin. While Morris purportedly designed the code to gauge the size of the internet, its aggressive replication mechanisms inadvertently weaponized it, creating the first instance of a digital pandemic.

Architectural Mechanics: The Tripartite Vector The Morris Worm is a seminal subject in cybersecurity not because of its destructive payload—it had none in the traditional sense of deleting files—but because of its sophisticated, multi-vector approach to propagation. It targeted VAX and Sun 3 systems running BSD Unix, employing a strategy that exploited three distinct layers of the computing stack [25].

- **The fingerd Buffer Overflow:** The worm’s primary entry point was a vulnerability in the `finger` daemon (`fingerd`), a standard Unix utility used to retrieve public information about network users. The worm transmitted a specially crafted request consisting of 536 bytes of data to the daemon. This input exceeded the buffer allocated by the program, causing a stack-based buffer overflow [25]. This overflow allowed the attacker to overwrite the return address on the stack with a pointer to the worm’s own code (shellcode), granting it execution privileges. This incident is historically significant as one of the first widespread exploitations of memory safety vulnerabilities—a class of flaw that continues to plague languages like C and C++ in 2025.
- **The Sendmail DEBUG Backdoor:** Concurrently, the worm probed the `sendmail` program, a mail transfer agent. It exploited a debugging feature (DEBUG) that had been left enabled in the production builds of the software on many systems. By issuing the DEBUG command, the worm could bypass authentication and execute commands as the privileged mail user [25]. This allowed it to issue a command to download the main body of the worm from the infecting machine. This vector highlights a perennial failure in software lifecycle management: the retention of development features in deployed environments, a vulnerability that echoes in modern API exposures.
- **Trust Relationships (rsh/rexec):** Perhaps most insidiously, the worm exploited the inherent trust architectures of the early internet. It leveraged the `.rhosts` and `/etc/hosts.equiv` files, which listed “trusted” hosts allowed to execute commands

via remote shell (**rsh**) without a password [25]. Once the worm compromised a single machine, it harvested these trust lists and immediately propagated to all connected, trusted systems. This mechanism is the direct ancestor of the “lateral movement” tactics used by modern ransomware groups like LockBit to traverse corporate intranets after compromising a single endpoint.

The Logic of Catastrophe: Failure in Flow Control The devastation caused by the Morris Worm—grinding systems to a halt—was the result of a flaw in its replication logic. Morris included a mechanism to check if a target machine was already infected. However, anticipating that system administrators might create “fake” infection processes to inoculate their systems, he programmed the worm to ignore a positive infection check 14% of the time [25].

This probabilistic decision proved fatal to the network. The worm replicated uncontrollably, with single machines hosting dozens or hundreds of concurrent worm processes. These processes competed for CPU cycles and memory, pushing load averages to infinity and rendering the machines unresponsive. Within 24 hours, an estimated 6,000 computers—10% of the entire internet—were infected, including systems at Harvard, Princeton, Stanford, NASA, and the Lawrence Livermore National Laboratory [25].

6.1.2 ILOVEYOU (2000): The Blueprint of Social Engineering

If the Morris Worm was a triumph of technical exploitation, the ILOVEYOU virus (also known as the LoveLetter worm) of May 2000 was a masterpiece of psychological manipulation. Originating from the Philippines, it demonstrated that the weakest link in any security chain is often the human user.

The Psychology of the Vector The attack vector was disarmingly simple yet devastatingly effective. Users received an email with the subject line “ILOVEYOU” and a message prompting them to check the attached “love letter” [26].

- **Emotional Exploitation:** The subject line exploited universal human curiosity and the desire for affection. Unlike the dry, technical context of the Morris Worm, ILOVEYOU attacked the user’s emotions.
- **The Double Extension Deception:** The attachment was named LOVE-LETTER-FOR-YOU.TXT.vbs. At the time, Windows operating systems hid known file extensions by default. Consequently, users saw LOVE-LETTER-FOR-YOU.TXT and assumed it was a harmless text file. In reality, it was a Visual Basic Script (VBS) executable [26].

The Payload: Destruction and Propagation Upon execution, the VBScript initiated a sequence of actions that combined the characteristics of a worm, a virus, and a Trojan:

- **Address Book Hijacking:** The worm accessed the victim’s Microsoft Outlook address book and automatically sent a copy of itself to every contact listed [26]. This was a critical innovation in social engineering; the malicious email appeared to come from a trusted friend, colleague, or family member, bypassing the recipient’s natural skepticism. This generated an “email storm” that overwhelmed corporate mail servers globally.

- **Data Destruction:** Unlike the Morris Worm, ILOVEYOU carried a destructive payload. It scanned the victim’s hard drive for specific file types—including JPEGs, MP3s, and Microsoft Office documents—and overwrote them with copies of itself or hid the original files [26]. This caused irreversible data loss for millions of users, targeting personal memories (photos) and professional work (documents).
- **Credential Theft:** A less publicized component of the malware attempted to harvest cached internet passwords and email them to a specific address in the Philippines [26].

The Legal Vacuum and Global Impact The virus infected tens of millions of computers, causing estimated damages of \$5.5 to \$8.7 billion [27]. The investigation traced the malware to Onel de Guzman, a computer science student in Manila. However, prosecutors faced a significant hurdle: at the time, the Philippines had no laws criminalizing computer hacking or malware creation [28].

De Guzman was released, and the charges were dropped. This legal impotence sparked an international outcry and led directly to the Philippine Congress enacting Republic Act No. 8792 (the E-Commerce Law) in June 2000 [29]. The incident underscored the borderless nature of cyber threats and the dangerous lag between technological capability and legal frameworks—a gap that international law enforcement continues to struggle with in the context of the 2024 ransomware cartels.

6.2 The 2024–2025 Vietnam Ransomware Wave: Deep Dive Case Studies

The 2024 wave was defined by three marquee incidents that paralyzed pillars of the Vietnamese economy: VNDirect (Finance), PVOIL (Energy), and Vietnam Post (Logistics). These were not random infections; they were strategic strikes against critical infrastructure.

6.2.1 The VNDirect Securities Incident (March 2024)

The Attack Timeline On Sunday, March 24, 2024, the Vietnamese financial sector was shaken by a massive attack on VNDirect, the country’s third-largest securities broker. VNDirect held approximately 7% of the market share on the Ho Chi Minh City Stock Exchange (HOSE), making it a systemic institution [30].

- **Infiltration and Encryption:** The attack commenced over the weekend, a tactical choice designed to maximize encryption time before the markets opened on Monday. CEO Nguyen Vu Long confirmed that a “group of professional hackers” had encrypted the company’s entire data estate [30].
- **Immediate Quarantine:** Recognizing the severity of the breach, the Hanoi Stock Exchange (HNX) took the drastic step of temporarily disconnecting VNDirect from its remote and online trading systems [30]. This “circuit breaker” action was necessary to prevent the malware from spreading laterally into the national exchange infrastructure, mirroring the “disconnect” response seen during the Morris Worm era.
- **The Ripple Effect:** The impact was immediate. VNDirect’s website, trading platform, and mobile apps went dark. Investors were locked out of their accounts, unable

to trade or withdraw funds. On the following Monday, transaction volumes on the HOSE dropped by 10% as a direct result of VNDirect’s client base being sidelined [30]. The company’s stock price fell nearly 4% in the immediate aftermath.

Technical Attribution: The LockBit Connection While initial reports were cautious, subsequent forensic analysis and threat intelligence linked the attack to the LockBit RaaS ecosystem.

- **Affiliate Operations:** Reports indicated that the attackers were affiliates of the LockBit ransomware group, with ransom demands rumored to be in the millions of dollars [31]. LockBit 3.0 (also known as LockBit Black) is notorious for its speed and modularity.
- **Lateral Movement:** Crucially, the attack was not limited to VNDirect. Related entities, including the investment firm IPA and the stock investment fund IPAAM, were also compromised [30]. This suggests that the attackers had compromised a central administrative domain or trusted pathway (similar to the `.rhosts` exploit of the Morris Worm) to move laterally across the corporate group’s subsidiaries.

Recovery and Resilience Recovery was a slow, painful process. It took eight days for VNDirect to restore its systems sufficiently to reconnect to the stock exchanges [32]. The recovery was executed in a four-stage phased approach, prioritizing the integrity of customer asset data before restoring full trading functionality [30]. This incident highlighted the lack of “hot” disaster recovery sites capable of immediate failover in the Vietnamese financial sector.

6.2.2 The PVOIL Ransomware Attack (April 2024)

Scarcely had the news cycle moved on from VNDirect when a second blow struck. On April 2, 2024, the Petrovietnam Oil Corporation (PVOIL), which commands 17% of Vietnam’s gasoline retail market, went dark [33].

IT-OT Convergence and the E-Invoice Crisis The PVOIL incident is a textbook example of the fragility introduced by the convergence of Information Technology (IT) and Operational Technology (OT).

- **The Disruption:** The attack struck at 00:00 on April 2. While the physical pumps at gas stations could still dispense fuel, the digital backbone—website, email, payment applications (PVOIL Easy, PVOIL B2B), and the electronic invoice (e-invoice) system—was encrypted [33].
- **Regulatory Paralysis:** In Vietnam, the issuance of e-invoices is a strict regulatory requirement for commercial transactions. The inability to issue these invoices meant that while PVOIL could sell gas to individual consumers (who rarely ask for VAT invoices), its B2B operations were paralyzed. Logistics fleets and industrial clients could not refuel without valid tax documentation, threatening a secondary supply chain crisis [34].

- **Supply Chain Ripple:** The paralysis of the “PVOIL B2B” application disrupted the wholesale distribution of gasoline, forcing logistics partners to scramble for alternative suppliers or risk grounding their fleets [35].

Attribution: ALPHV/BlackCat Threat intelligence strongly points to the ALPHV (BlackCat) ransomware group as the perpetrator. BlackCat is known for targeting the energy and industrial sectors (e.g., the 2022 attack on German oil companies) [36].

- **Technical Signature:** BlackCat is written in Rust, a modern programming language that offers memory safety and cross-platform compatibility (Windows and Linux). This makes the malware highly resistant to reverse engineering and traditional signature-based detection [37].
- **Triple Extortion:** BlackCat affiliates often employ “triple extortion”: encryption, data theft (threat of leakage), and the threat of Distributed Denial of Service (DDoS) attacks if the ransom is not paid [37].

The Hybrid Recovery Model PVOIL’s recovery was notably faster than VNDirect’s, driven by the strategic necessity of fuel distribution.

- **State Intervention:** The Department of Cyber Security and High-Tech Crime Prevention (A05) and the Authority of Information Safety (AIS) mobilized immediately to assist [35].
- **The Third-Party Workaround:** In a critical defensive maneuver, PVOIL collaborated with the General Department of Taxation and a third-party technology provider to deploy a temporary e-invoice solution. By 3:00 PM on April 3—less than 48 hours after the attack—PVOIL resumed issuing invoices via this external system [38]. This highlights the vital importance of redundancy and alternative service providers in business continuity planning.

6.2.3 Vietnam Post (June 2024)

The third major strike occurred on June 4, 2024, targeting the Vietnam Post Corporation (VNPost), the national postal service.

The Logistics Blackout At 3:10 AM, VNPost’s IT monitoring systems detected the encryption event. The corporation immediately activated a “kill switch,” disconnecting its data centers from the internet to isolate the breach [39].

- **Selective Impact:** The attack took down the `vnpost.vn` domain and all parcel tracking applications, leaving customers blind to the status of their shipments. However, notably, the postal finance and public administration services remained operational [39]. This suggests either a segmented network architecture that protected the financial arm or a targeted strike focused specifically on the logistics database.

The Precursor: The Kibana Leak The Vietnam Post incident illustrates the concept of “dwell time” and reconnaissance. In November 2023—seven months prior to the ransomware attack—security researchers discovered that VNPost had left a Kibana dashboard (used for

data visualization and analytics) open to the public internet without password protection [40].

- **The Intelligence Goldmine:** This leak exposed over 1.2 terabytes of data, comprising 226 million event logs. These logs included employee email addresses, system error messages, and network topology details.
- **The Kill Chain:** It is highly probable that the ransomware actors used this leaked data to map the network, identify administrator accounts, and plan the June attack with precision. This underscores the critical lesson that data leaks are often the precursor to kinetic cyberattacks.

6.3 Strategic Analysis and Defensive Postures

6.3.1 The Economic Calculus

The “Big Game Hunting” strategy is driven by simple economics. The rapid digitization of Vietnam’s assets has created target-rich environments where the cost of downtime exceeds the ransom demand.

- **Downtime Costs:** For VNDirect, the cost was not just the potential ransom but the loss of market liquidity (-10% on HOSE) and investor trust [30].
- **The Ransom Dilemma:** While the Vietnamese government advises against payment, the lack of a strict legal prohibition creates a gray zone. PVOIL’s ability to recover via state-supported workarounds offers a model for resilience without capitulation.

6.3.2 Government Response

In response to the wave, the Prime Minister issued a directive in April 2024 mandating a comprehensive cybersecurity review [40]. This has had a tangible effect: by late 2024, the Ministry of Information and Communications (MIC) reported a 57.4% year-on-year decline in cyber incidents, attributed to heightened awareness and the deployment of defensive technologies [41]. However, experts warn that while the volume of attacks may drop, the severity of targeted campaigns will likely increase.

6.3.3 Recommendations for Resilience

Based on the autopsy of these incidents, the following strategic imperatives are clear for Vietnamese critical infrastructure:

1. **Immutable Backups:** The PVOIL recovery underscores the necessity of backups that are offline or immutable, ensuring they cannot be encrypted by the attacker.
2. **Network Segmentation:** The spread from VNDirect to IPAAM mirrors the trust exploitation of the Morris Worm. Strict segmentation between corporate IT, OT, and subsidiary networks is non-negotiable.
3. **Zero Trust Architecture:** The reliance on VPNs is a single point of failure. Moving to a Zero Trust model—where every access request is verified regardless of origin—is essential to stop credential-based attacks [42].

4. **Supply Chain Auditing:** Organizations must audit the security posture of their third-party providers (e.g., e-invoice vendors) to mitigate downstream risk.

Conclusion

The 2024–2025 Vietnam ransomware wave serves as a grim validation of the lessons ignored from history. The Morris Worm taught us that architectural flaws in connectivity lead to systemic contagion. The ILOVEYOU virus taught us that human curiosity is a perennial vulnerability. Today, groups like LockBit and BlackCat have industrialized these lessons, leveraging the complexity of modern digital economies to hold nations ransom.

The incidents at VNDirect, PVOIL, and Vietnam Post were not merely crimes; they were stress tests of Vietnam’s digital sovereignty. They revealed that in a hyper-connected economy, security cannot be an afterthought. As the threat landscape shifts toward AI-driven attacks and supply chain compromise in 2025, the defense must evolve from reactive patching to proactive, resilience-based design. The era of “Big Game Hunting” has arrived in Southeast Asia, and the only defense is a digital immune system that assumes the breach is inevitable.

Statistical Appendix: The Scope of the Threat

Metric	Data Point	Context
Total Ransomware Events (Q1 2024)	~13,000	Detected on Vietnamese information systems [39]
Computers Attacked (2024)	155,640	Nationwide across Vietnam [43]
Estimated Economic Loss (2024)	Tens of trillions VND	Aggregate damage to Vietnamese businesses [43]
VNDirect Market Impact	–10% volume	Drop in HOSE transaction volume [30]
Global Cyber Damage (2024 est.)	\$9.5 trillion	Cybersecurity Ventures projection [43]
VNPost Data Leak	1.2 TB / 226M logs	Kibana exposure (Nov 2023) [40]
Attack Decline (Late 2024)	–57.4% YoY	Ministry of Information and Communications statistics (Oct 2024) [41]

Table 3: Key statistical indicators of the 2024–2025 cyber threat landscape

7 Defense and Mitigation Strategies

7.1 General

Malicious software (malware) not only causes damage at the technical level but also directly affects the confidentiality, integrity, and availability of information systems [44]. Kim and Michael point out that defending against malware cannot rely on a single countermeasure; instead, it requires the integration of multiple systematic strategies, including technology, processes, and human factors.

The *Defense and Mitigation Strategies* section focuses on core measures aimed at reducing the likelihood of successful attacks and minimizing damage when attacks occur.

7.2 Defense in Depth

7.2.1 Core Concept

Defense in Depth is a malware defense strategy based on the principle that no security control is absolute [44]. Therefore, multiple independent layers of protection must be deployed to operate concurrently and complement one another.

According to Kim and Michael, modern malware:

- Does not rely solely on malicious code,
- But also exploits software vulnerabilities, weak system configurations, and user behavior.

If a system relies on only a single defensive layer (for example, antivirus software), once that layer is bypassed, the entire system becomes exposed.

Defense in Depth aims to reduce the probability of a successful attack and to limit the extent of damage when an attack occurs.

7.2.2 Defense in Depth in the Context of Malware Protection

In Chapter 8, Defense in Depth is considered the foundation of all malware defense strategies [44] because malware may evade individual security mechanisms but finds it difficult to bypass multiple protective layers simultaneously.

Defense in Depth does not focus solely on malware detection; it also encompasses intrusion prevention, containment of malware propagation, detection of abnormal behavior, and support for incident response. This approach reflects the reality that malware is not always detected immediately upon entry.

7.2.3 Typical Defense Layers

Defense in Depth typically includes multiple layers, each with a distinct role:

- **User Layer:** system usage policies, security awareness training, and regulations regarding email, attachments, and passwords. This layer is the most vulnerable to exploitation but also the most cost-effective and efficient when properly trained.

- **Host / Workstation Layer:** antivirus and anti-malware solutions, operating system hardening, and user privilege control. The goal is to prevent malware execution and restrict privileges if compromise occurs.
- **Application Layer:** software patching, input validation, and application-level access control. Many malware attacks exploit application vulnerabilities; therefore, this layer helps prevent exploitation at the source.
- **Network Layer:** firewalls, IDS/IPS, network segmentation, and DMZs. This layer aims to prevent malware from communicating with command-and-control servers and to detect abnormal traffic.
- **Data Layer:** data backups, access control, and encryption. Even if malware penetrates the system, data can still be protected or recovered.

7.2.4 Relationship to Other Chapters

Defense in Depth is closely linked to content presented in other chapters, particularly Chapter 1 (Seven Domains of IT Infrastructure) and Chapter 6 (Access Controls). Each domain represents a distinct defensive layer, illustrating that Defense in Depth spans the entire information security architecture.

7.2.5 Practical Scenario

In a malware attack delivered via email, a malicious message may bypass spam filters and be downloaded by a user. However, antivirus software may detect and block the malicious file. If the malware still executes, intrusion detection systems may identify abnormal network traffic, enabling administrators to isolate the infected device promptly. As a result, malware does not spread, no data breach occurs, and the incident is contained early.

7.2.6 Summary

Defense in Depth does not aim to guarantee that systems will never be attacked. Instead, it seeks to make attacks more difficult to succeed, limit damage, and provide sufficient time for detection and response. It serves as the foundational strategy for the entire Defense and Mitigation Strategies section in Chapter 8.

7.3 Patch Management

7.3.1 Concept and Role in Malware Defense

Patch Management is the process of identifying, deploying, and controlling security patches for operating systems, applications, and system components. In Chapter 8, Kim and Michael emphasize that malware attacks typically do not require sophisticated techniques but instead exploit publicly known vulnerabilities that remain unpatched [44].

Therefore, Patch Management is not merely a system maintenance task but a proactive malware defense strategy.

7.3.2 Why Patch Management Is Important

According to the textbook, most successful malware attacks occur because:

- Systems run outdated software,
- Vulnerabilities are publicly known,
- Attackers have automated exploitation tools.

This situation creates a “vulnerability window”—the period between vulnerability disclosure and patch deployment. Patch Management aims to minimize this window, thereby reducing malware entry and propagation.

7.3.3 Patch Management in Defense and Mitigation

Within Defense and Mitigation Strategies, Patch Management:

- Prevents malware at the intrusion stage,
- Reduces privilege escalation opportunities,
- Limits large-scale automated attacks such as worms and botnets.

Although Patch Management does not detect malware, it renders systems non-exploitable and increases attacker effort. It is therefore a foundational preventive measure.

7.3.4 Relationship to Other Chapters

Patch Management relates directly to Chapter 3 (Risks, Threats, and Vulnerabilities), where malware is a threat, software flaws are vulnerabilities, and patching reduces vulnerabilities and overall risk.

It also connects to Chapter 9 (Security Operations and Administration), emphasizing that patching is both a technical and managerial responsibility.

7.3.5 Common Patch Management Challenges

Kim and Michael identify several challenges:

- Fear that patches may disrupt system stability,
- Complex infrastructures that hinder synchronized updates,
- Lack of testing procedures prior to deployment.

Nevertheless, the textbook emphasizes that the risk of not patching generally exceeds the risk of patching.

7.3.6 Case Study

WannaCry Ransomware: The malware exploited a Windows SMB vulnerability for which Microsoft had already released a patch. Organizations that failed to update were widely affected, leading to massive data encryption, operational disruption, and financial loss. This

case demonstrates that malware does not require zero-day exploits and that weak patch management represents systemic risk [44, 23].

7.3.7 Organizational Scenario

An organization without a formal patching process operates outdated server software, allowing malware to exploit known vulnerabilities and gain system control. In contrast, organizations with effective patch management neutralize vulnerabilities early, blocking attacks at the outset and shifting from reactive to proactive defense.

7.3.8 Summary

Patch Management may not produce immediately visible results, but it forms the backbone of malware prevention by significantly reducing system exploitability and attack surface.

7.4 Backup Strategy – The 3-2-1 Rule

7.4.1 The Role of Backup in Malware Defense

In Chapter 8, Kim and Michael emphasize that not all malware attacks can be completely prevented. Once malware has successfully infiltrated a system and caused damage—especially in the case of ransomware—the ability to recover becomes the determining factor in the overall impact of the incident [44].

Backup does not prevent malware intrusion; however, it:

- Reduces damage,
- Ensures data recovery capability,
- Maintains system availability after an attack.

Therefore, backup is considered the final defensive measure in the Defense and Mitigation Strategies chain [44].

7.4.2 What Is the 3-2-1 Rule?

Kim and Michael present the 3-2-1 rule as a best practice for data backup, which includes:

- **Three copies of data:** one primary copy and at least two backup copies,
- **Two different types of storage media:** for example, internal hard drives and external storage or cloud services,
- **One backup stored off-site or offline:** to prevent malware from destroying all copies simultaneously.

The objective of this rule is to eliminate single points of failure in data protection.

7.4.3 Why Backup Is Especially Important Against Ransomware

Ransomware is a form of malware that not only infiltrates systems but also encrypts or destroys data, rendering systems unusable. According to the textbook, without proper backups:

- Organizations may be forced to pay ransom,
- Or accept permanent data loss and severe operational disruption.

Backup enables organizations to:

- Avoid dependency on attackers,
- Recover data independently,
- Minimize financial and operational impact.

7.4.4 Relationship to Other Chapters

Backup directly relates to the CIA Triad discussed in Chapter 1:

- **Availability:** ensuring systems remain operational after incidents,
- **Integrity:** restoring data to a correct and trusted state.

It also serves as a core component of Disaster Recovery Plans (DRP) and Business Continuity Plans (BCP) discussed in Chapter 11, demonstrating that backup supports both security and organizational continuity.

7.4.5 Practical Scenarios

Scenario 1: Failure to Apply the 3-2-1 Rule An organization maintains only a single online backup. When ransomware infiltrates the system, both the primary data and backup are encrypted, making recovery impossible. The result is prolonged downtime, significant financial loss, and reputational damage.

Scenario 2: Proper Implementation of the 3-2-1 Rule The organization maintains an offline backup inaccessible to ransomware. After the attack, systems are restored without paying ransom, and the overall impact of the malware attack is significantly reduced.

7.4.6 Significance of Backup Strategy

Backup Strategy does not replace preventive controls such as firewalls or patch management. Instead, it serves as a final safeguard when all other defenses fail. In Chapter 8, backup is regarded as a mitigation measure rather than a prevention mechanism.

7.4.7 Summary

The 3-2-1 backup strategy enables organizations to remain resilient against data-destructive malware. Without effective backups, a malware incident can escalate from a technical issue into an organizational catastrophe.

7.5 Incident Response Lifecycle

7.5.1 Why Incident Response Is Critical in Malware Defense

Kim and Michael emphasize that no organization can guarantee complete immunity from malware attacks. Consequently, the key concern is not only how to prevent attacks but also how to respond once an attack has occurred.

The Incident Response Lifecycle provides a structured approach that enables organizations to:

- Detect malware incidents promptly,
- Control and contain spread,
- Recover systems securely,
- Prevent recurrence.

Without such a process, responses are often reactive, fragmented, and may result in greater damage than the attack itself.

7.5.2 Incident and Incident Response

An **incident** is a security event that compromises the confidentiality, integrity, or availability of a system, such as malware infection, botnet detection, or ransomware activity.

Incident Response refers to a planned set of actions designed to manage, contain, and recover from such incidents. According to Chapter 8, malware incidents must be handled through a standardized lifecycle rather than ad-hoc reactions [44].

7.5.3 Stages of the Incident Response Lifecycle

1. **Preparation:** development of incident response policies, deployment of monitoring tools, and assignment of response roles.
2. **Identification:** detection of malware indicators and assessment of incident scope.
3. **Containment:** isolation of affected systems to prevent further spread.
4. **Eradication:** removal of malware, patching of exploited vulnerabilities, and elimination of insecure configurations.
5. **Recovery:** restoration of systems from secure backups and careful monitoring post-recovery.
6. **Lessons Learned:** analysis of root causes and improvement of defenses and procedures.

7.5.4 Relationship to Other Chapters

Incident Response relies heavily on monitoring and logging mechanisms discussed in Chapter 10, which support timely identification and analysis. Recovery activities align with contingency planning concepts presented in Chapter 11, linking prevention and resilience.

7.5.5 Practical Scenario

In a botnet infection scenario, abnormal traffic is detected by IDS (Identification). The affected server is disconnected from the network (Containment), malware is removed and vulnerabilities patched (Eradication), data is restored from backups (Recovery), and security procedures are updated (Lessons Learned). As a result, the incident is controlled without spreading across the infrastructure.

7.5.6 Significance of Incident Response Lifecycle

The Incident Response Lifecycle does not eliminate malware but significantly reduces impact and downtime. It ensures that organizations respond systematically rather than chaotically, making it an essential element of Defense and Mitigation Strategies.

7.6 User Awareness

7.6.1 Why User Awareness Is a Malware Defense Strategy

In Chapter 8, Kim and Michael highlight that humans are the most frequently targeted element in malware attacks [44]. Even with robust technical controls, attackers often bypass technology by exploiting user behavior.

Common malware delivery methods such as phishing emails, malicious attachments, and deceptive links rely on users performing unsafe actions. Therefore, User Awareness is considered the first line of defense and holds equal importance to technical controls.

7.6.2 Core Components of User Awareness

User Awareness focuses on:

- Helping users recognize attack indicators,
- Establishing secure system usage habits,
- Reducing malware entry at the initial stage.

Training programs typically include:

- Identifying phishing and spear-phishing emails,
- Exercising caution with attachments and links,
- Complying with password and authentication policies,
- Reporting suspicious activity promptly.

The goal is not to turn users into security experts but to minimize common risky behaviors.

7.6.3 User Awareness in the Context of Chapter 8

According to the textbook, many malware attacks succeed because users open untrusted attachments, enter credentials into fraudulent websites, or ignore security warnings. User Awareness disrupts the attack chain at its earliest stage, before malware can exploit technical vulnerabilities.

7.6.4 Relationship to Other Chapters

User Awareness complements access control mechanisms discussed in Chapter 6. Strong authentication controls become ineffective if users voluntarily disclose credentials.

It also supports cryptographic protections described in Chapter 7, as encryption and digital signatures are only effective when users are not deceived into interacting with malicious websites.

7.6.5 Practical Scenario

In a phishing attack scenario, two employees receive a fraudulent email. An untrained employee opens the attachment, resulting in malware installation and internal system compromise. A trained employee recognizes suspicious indicators, avoids opening the file, and reports the email. The difference lies not in technology but in user awareness.

7.6.6 Role of User Awareness in Defense and Mitigation

User Awareness does not replace firewalls, antivirus software, or patch management. Instead, it complements technical controls and reduces the number of incidents requiring technical response. A secure system with unaware users remains highly vulnerable.

7.6.7 Summary

In Chapter 8, User Awareness is presented as the human element of malware defense. It serves as a continuous first line of defense and represents a low-cost, high-impact security measure that transforms users from weaknesses into active contributors to security.

7.7 Overall Summary

Defense and Mitigation Strategies in Chapter 8 demonstrate that effective malware defense requires a comprehensive and integrated approach:

- Defense in Depth provides a layered security foundation,
- Patch Management reduces exploitable vulnerabilities,
- Backup Strategy (3-2-1) ensures post-incident recovery,
- Incident Response Lifecycle enables controlled handling of attacks,
- User Awareness prevents malware at the earliest entry point.

Together, these strategies reinforce one another, forming a cohesive and resilient malware defense framework consistent with the principles outlined in Chapter 8 [44].

8 Future Trends in Malicious Software

As digital transformation accelerates, malicious software is evolving from static, fixed-rule programs into intelligent, stealthy, and adaptive digital weapons. Based on current developments in the cybersecurity landscape, the following five trends represent the next generation of malware threats:

8.1 AI-Powered and Autonomous Malware

- **Definition:** This refers to malware that integrates Artificial Intelligence (AI) and Machine Learning (ML) to automate decision-making processes that previously required human intervention.
- **The Mechanism:** Unlike traditional malware that follows a hard-coded path, AI-powered malware can perform "Automated Reconnaissance." It analyzes the victim's security environment, identifies specific firewall rules or antivirus signatures, and then modifies its own code (*Advanced Polymorphism*) to bypass those defenses.
- **The Threat:** AI enables malware to stay dormant until the most opportune moment. Furthermore, AI-driven *Deepfakes* (cloning voices or faces) will make *Social Engineering* almost impossible to detect, as employees can no longer trust their eyes or ears during video calls [45, 46].

8.2 Fileless Malware and "Living-off-the-Land" (LotL)

- **Definition:** A sophisticated technique where the malicious code resides entirely in the computer's volatile memory (RAM) instead of being saved as a file on the hard drive.
- **The Mechanism:** Most antivirus software works by scanning files on the disk for known "bad signatures." Fileless malware avoids this by exploiting the "trust" of the Operating System. It uses legitimate system administrative tools, such as *PowerShell* or *Windows Management Instrumentation (WMI)*, to execute malicious commands directly in memory.
- **The Threat:** Because the attacker is using "authorized" tools already found on the victim's computer, this is called "Living-off-the-Land." Since no "infected file" is ever created, it leaves almost no digital footprint, making it one of the most difficult types of malware to detect and remove [47].

8.3 IoT Botnets and Critical Infrastructure Threats

- **Definition:** The large-scale infection of "Internet of Things" (IoT) devices—ranging from smart cameras and thermostats to industrial sensors—to build massive, distributed zombie networks.
- **The Mechanism:** Billions of IoT devices are shipped with weak security frameworks and default passwords that are rarely changed. Malware like the *Mozi* or *Mirai* variants can scan the entire IPv4 address space in hours, infecting vulnerable devices and turning them into "bots" waiting for a command [1].
- **The Threat:** While one smart device is weak, a *Botnet* of millions of devices can launch a *Distributed Denial of Service (DDoS)* attack powerful enough to disable na-

tional power grids, banking systems, or healthcare networks, shifting the threat from digital inconvenience to physical safety risks.

8.4 Ransomware 3.0: The Triple Extortion Model

- **Definition:** An advanced evolution of ransomware that applies three distinct layers of psychological and financial pressure to ensure the victim pays the ransom.
- **The Mechanism:** This trend moves beyond simple data encryption:
 1. **Encryption:** Locking the victim's data to stop operations (Availability loss).
 2. **Exfiltration (Data Theft):** Stealing sensitive records and threatening to leak them online (Confidentiality loss).
 3. **Harassment:** Directly contacting the company's clients, partners, or employees to inform them of the breach and pressure the organization from all sides.
- **The Threat:** This model makes backups (the traditional defense) ineffective. Even if an organization can restore its data from a backup, it cannot "un-leak" a secret or repair the ruined reputation caused by public data disclosure [45].

8.5 Supply Chain Attacks (Software Poisoning)

- **Definition:** A strategic attack where malware is injected into a trusted software vendor's product or update mechanism to reach thousands of downstream customers at once.
- **The Mechanism:** Instead of attacking a well-defended target (like a bank), hackers compromise a software provider that the target trusts. They hide a *backdoor* inside a legitimate software update.
- **The Threat:** When the customer clicks "Update Now" for a trusted app, they are unknowingly installing malware with administrative privileges. Because the update is "signed" and comes from a "trusted" source, the system's defenses are completely bypassed. A single supply chain compromise, such as the *SolarWinds* incident, can cause a mass-infection event globally [46].

9 Conclusion

The study of Chapter 8 shows that malicious software has changed from a small technical problem into a professional criminal tool. As malware becomes smarter, our ways of defending must also improve.

9.1 Final Summary of Key Lessons

Through our research, we can conclude three main things:

- **Technology is not the only answer:** We can have the best firewalls, but *Social Engineering* (tricking people) is still the easiest way for hackers to get in. Educating users (*User Awareness*) is the most important layer of defense [1].
- **Protecting the CIA Triad:** Every attack we studied targets the pillars of security. *Spyware* breaks Confidentiality, *Viruses* break Integrity, and *Ransomware* destroys Availability. A good security plan must protect all three [1].
- **Focus on Resilience:** Since threats like "Fileless" and "AI malware" are hard to stop, organizations must focus on **Cyber Resilience**. This means being ready to recover quickly using a strong *3-2-1 Backup Strategy* and a clear *Incident Response* plan.

9.2 The Reality in Vietnam

The 2024-2025 Ransomware attacks in Vietnam, which hit companies like VNDIRECT and PVOIL, prove that the theories in Chapter 8 are very real. These attacks caused huge losses and showed that Vietnamese businesses must implement *Defense in Depth* immediately to survive in the digital age.

9.3 Final Words

Malware will never stop evolving. However, by staying proactive with *Patch Management*, using modern AI-based defense tools, and constantly teaching users to be careful, we can stay safe. Security is not a one-time job; it is a continuous journey of learning and adapting.

References

- [1] David Kim and Michael G. Solomon. *Fundamentals of Information Systems Security*. Jones & Bartlett Learning, Burlington, MA, 3rd edition, 2018. Chapter 8: Malicious Software and Attack Vectors.
- [2] Swiss Cyber Institute. Top 12 worst computer viruses in history (& what they taught us about cybersecurity), 2025. Truy cập ngày March 22, 2026.
- [3] Mikalai Shershan. Twilio data breach: what happened and how to protect yourself. <https://onerep.com/blog/twilio-data-breach-how-to-protect-yourself>, 2025.
- [4] Europol. World’s most dangerous malware emotet disrupted through global action. <https://www.europol.europa.eu/media-press/newsroom/news/world%E2%80%99s-most-dangerous-malware-emotet-disrupted-through-global-action>, 2021.
- [5] IBM. What is the log4j vulnerability? <https://www.ibm.com/think/topics/log4j>.
- [6] Rebecca Klar Maggie Miller, Chris Mills Rodrigo. Hillicon valley — apache vulnerability sets off alarm bells. <https://thehill.com/policy/technology/overnights/585832-hillicon-valley/>, 2021.
- [7] The Guardian. Ddos attack that disrupted internet was largest of its kind in history, experts say. <https://www.theguardian.com/technology/2016/oct/26/ddos-attack-dyn-mirai-botnet>, 2016.
- [8] David Kim and Michael G. Solomon. *Fundamentals of Information Systems Security*. Jones & Bartlett Learning, 4th edition, 2021. Chapter 8: Malicious Software and Attack Vectors.
- [9] Taipei Times. Vietnamese hacker becomes cyberagent. <https://www.taipeitimes.com/News/world/archives/2022/05/26/2003778844>, 2022.
- [10] Ministry of Science and Technology Vietnam. Hieu pc: From hacker to cybersecurity expert. <https://mst.gov.vn/hieu-pc-tu-mot-hacker-gioi-nhat-the-gioi-den-chuyen-gia-ve-an-ninh-mang-197152090.htm>, 2021.
- [11] The Guardian. Lulzsec: what they did, who they were and how they were caught. <https://www.theguardian.com/technology/2013/may/16/lulzsec-hacking-fbi-jail>, 2013.
- [12] BBC News. George floyd: Anonymous hackers re-emerge amid us unrest. <https://www.bbc.co.uk/news/technology-52879000>, 2020.
- [13] EBSCO Research Starters. Anonymous. <https://www.ebsco.com/research-starters/biography/anonymous>, 2024.
- [14] Control Engineering. Ithrowback attack: An insider releases 265,000 gallons of sewage on the maroochy shire. <https://www.controleng.com/throwback-attack-an-insider-releases-265000-gallons-of-sewage-on-the-maroochy-shire>, 2021.

- [15] EBSCO Research Starters. Stuxnet. <https://www.ebsco.com/research-starters/computer-science/stuxnet>, 2024.
- [16] Dan Tri. The world’s first terrifying digital weapon. <https://dantri.com.vn/cong-nghe/stuxnet-vu-khi-ky-thuat-so-dang-so-dau-tien-tren-the-gioi-202409210526244.htm>, 2024.
- [17] Reuters. Ex-google engineer convicted of stealing ai secrets for chinese companies. <https://www.reuters.com/legal/government/ex-google-engineer-convicted-stealing-ai-secrets-chinese-companies-2026-01-29/>, 2026.
- [18] VNExpress. Ex-google engineer convicted of stealing ai secrets for chinese companies. <https://e.vnexpress.net/news/tech/tech-news/ex-google-engineer-convicted-of-stealing-ai-secrets-for-chinese-companies-5011854.html>, 2026.
- [19] A.W. Junaid. Mafiaboy’s moment: The 2000 denial-of-service attacks. <https://awjunaid.com/cyber-security/mafiaboys-moment-the-2000-denial-of-service-attacks-that-shook-the-internet/>, 2025.
- [20] Fortinet. Solarwinds cyber attack: An overview. <https://www.fortinet.com/uk/resources/cyberglossary/solarwinds-cyber-attack>.
- [21] TechTarget. Solarwinds hack explained: Everything you need to know. <https://www.techtarget.com/whatis/feature/SolarWinds-hack-explained-Everything-you-need-to-know>, 2023.
- [22] UK National Cyber Security Centre. Moveit vulnerability and data extortion incident. <https://www.ncsc.gov.uk/information/moveit-vulnerability>, 2023.
- [23] Wannacry ransomware cyber attack. Technical report, National Audit Office (UK), 2017. Public sector cyber incident report.
- [24] Cloudflare. What is wannacry ransomware? [WhatwastheWannaCryransomwareattack?](https://www.cloudflare.com/what-is-wannacry-ransomware/)
- [25] Federal Bureau of Investigation. A study on the morris worm. https://www.researchgate.net/publication/337499010_A_study_on_the_Morris_Worm, Akshay Jajoo. Hisstory detailing the 1988 incident, the first major denial-of-service attack, and its legal aftermath.
- [26] Huntress. ILOVEYOU malware: Analysis, detection, removal. <https://www.huntress.com/threat-library/malware/iloveyou>, 2024. Technical breakdown of the VBScript mechanics and social engineering tactics used.
- [27] EBSCO Research Starters. ILOVEYOU virus attacks computers. <https://www.ebsco.com/research-starters/computer-science/iloveyou-virus-attacks-computers>. Academic summary of the virus’s propagation methods and global economic impact.
- [28] Computerworld Staff. ‘Love Bug’ virus charges reportedly dropped. *Computerworld*, August 2000. Accessed: February 3, 2026. Contemporary report confirming the dismissal of charges due to the lack of applicable cybercrime legislation.

- [29] Respicio & Co. Law Firm. The Emergence and Significance of RA 8792: A Comprehensive Legal Overview. <https://www.respicio.ph/dear-attorney/the-emergence-and-significance-of-ra-8792-a-comprehensive-legal-overview>, 2024. Accessed: February 3, 2026. Legal analysis of the Electronic Commerce Act of 2000, enacted on June 14, 2000, in response to the ILOVEYOU virus.
- [30] The Record. Cyberattack on Vietnam securities broker disrupts stock markets. <https://therecord.media/vietnam-securities-broker-cyberattack-vndirect>, 2024. Detailed timeline of the VNDirect incident and its market liquidity impact.
- [31] Sangfor Technologies. The top ransomware attacks in 2024. <https://www.sangfor.com/blog/cybersecurity/ransomware-attacks-2024-top-ransomware-headlines>, 2024. Global context for the ransomware wave, noting LockBit and Brain Cipher variants.
- [32] Dark Reading. Ransomware, junk bank accounts: Cyber threats proliferate in Vietnam. <https://www.darkreading.com/cyber-risk/ransomware-junk-bank-accounts-cyberthreats-proliferates-in-vietnam>, 2024. Investigation into the “junk bank account” networks used for money laundering.
- [33] The Investor. Gasoline retailer PVOIL hit by ransomware attack. <https://theinvestor.vn/gasoline-retailer-pvoil-hit-by-ransomware-attack-d9363.html>, 2024. Report on the PVOIL incident focusing on the paralysis of the e-invoice system.
- [34] Vietbao.vn. PVOIL was subjected to a data encryption attack, causing system downtime. <https://vietbao.vn/en/pvoil-bi-tan-cong-ma-hoa-du-lieu-he-thong-ngung-tre-479453.html>, 2024. Coverage of the initial service blackout and impact on app users.
- [35] VNCS. Why can the PVOIL system recover quickly after a ransomware attack? <https://vncs.vn/en/tin-tuc/detail-why-can-the-pvoil-system-recover-quickly-after-a-ransomware-attack-341>, 2024. Technical assessment of the state-assisted recovery effort.
- [36] Trend Micro. Ransomware spotlight: BlackCat. <https://www.trendmicro.com/vinfo/us/security/news/ransomware-spotlight/ransomware-spotlight-blackcat>, 2024. Profile of the ALPHV/BlackCat group and their targeting of industrial sectors.
- [37] Varonis. BlackCat ransomware (ALPHV). <https://www.varonis.com/blog/blackcat-ransomware>, 2024. Deep dive into the Rust-based malware architecture and triple extortion tactics.
- [38] PVOIL. PRESS RELEASE regarding the restoration of PVOIL’s information technology system. <https://pvoil.com.vn/en/press-release-regarding-the-restoration-of-pvoils-information-technology-system>, 2024. Official statement on recovery timelines and the e-invoice workaround.
- [39] VNCS. Breaking news: Another large enterprise in Vietnam was attacked by ransomware. <https://vncs.vn/en/tin-tuc/>

- [detail-breaking-news-another-large-enterprise-in-vietnam-was-attacked-by-ransomware](#) 2024. Incident report on the Vietnam Post attack and immediate containment measures.
- [40] The Record. Vietnam's state postal service claims to restore its systems after cyberattack. <https://therecord.media/vietnam-claims-restore-services-cyberattack>, 2024. Follow-up on Vietnam Post recovery, linking the attack to a prior Kibana leak.
 - [41] Ministry of Information and Communications. Vietnam sees sharp decline in cyber attacks as awareness of security rises. <https://beta-en.mic.gov.vn/vietnam-sees-sharp-decline-in-cyber-attacks-as-awareness-of-security-rises-19724111.htm>, 2024. Late-2024 statistics showing a 57.4% drop in incidents due to better defense.
 - [42] Viettel Cyber Security. Viettel releases 2024 Vietnam cybersecurity threat landscape report. <https://viettel.com.vn/en/news-events/news/viettel-releases-2024-vietnam-cybersecurity-threat-landscape-report/>, 2024. Strategic assessment of future threats, recommending Zero Trust architectures.
 - [43] Bkav Corporation. 60% of Vietnamese businesses are not equipped with adequate security solutions. <https://www.bkav.com/top-new/-/view-content/2327397/60-of-vietnamese-businesses-are-not-equipped-with-adequate-security-solutions>, 2024. Statistical analysis of the readiness gap and economic loss estimates.
 - [44] David Kim and Michael G. Solomon. *Fundamentals of Information Systems Security*. Jones & Bartlett Learning, Burlington, MA, 4th edition, 2018.
 - [45] IBM Security. Cost of a data breach report 2024: Ai and automation in cybersecurity, 2024.
 - [46] Murugiah Souppaya and Karen Scarfone. Guide to malware incident prevention and handling for desktops and laptops. Technical Report SP 800-83 Rev. 1, National Institute of Standards and Technology (NIST), 2023.
 - [47] CrowdStrike. 2024 global threat report: Cyberattacks in the age of ai, 2024.
 - [48] Ministry of Information and Communications. Enhancing network security critical to defend against attacks. <https://english.mic.gov.vn/enhancing-network-security-critical-to-defend-against-attacks-19724042309573251.htm>, 2024. Government strategy report outlining national cybersecurity defenses post-2023.
 - [49] Vietnam News. Ransomware attack hits Vietnam Post. <https://vietnamnews.vn/economy/1656859/ransomware-attack-hits-vietnam-post.html>, 2024. News coverage detailing the logistics disruption and service blackouts.
 - [50] The Investor. Vietnam postal services crippled by ransomware attack. <https://theinvestor.vn/vietnam-postal-services-crippled-by-ransomware-attack-d10489.html>, 2024. Analysis of the operational impact on national logistics infrastructure.
 - [51] VietNamNet. CMC Group hit by ransomware attack, authorities launch investigation. <https://vietnamnet.vn/en/>

- [cmc-group-hit-by-ransomware-attack-authorities-launch-investigation-2391420.html](#), 2024. Report on attacks targeting major technology groups in Vietnam.
- [52] Ministry of Information and Communications. LockBit, BlackCat, and stealer malware among top threats in Vietnam q3 2024. <https://beta-en.mic.gov.vn/lockbit-blackcat-and-stealer-malware-among-top-threats-in-vietnam-q3-2024-197241104.htm>, 2024. Official government warning on the rise of Stealer malware and RaaS syndicates.
- [53] VietNamNet. VNDirect cyberattack causes big splash on stock market. <https://vietnamnet.vn/en/vndirect-cyberattack-causes-big-splash-on-stock-market-2264185.html>, 2024. Analysis of the financial shockwaves and investor sentiment following the breach.
- [54] Palo Alto Networks Unit 42. Ransomware retrospective 2024: Unit 42 leak site analysis. <https://unit42.paloaltonetworks.com/unit-42-ransomware-leak-site-data-analysis-all-2023/>, 2024. Statistical analysis of encryption speeds and RaaS leak site activity.
- [55] CISA. Understanding ransomware threat actors: LockBit. <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-165a>, 2023. Cybersecurity advisory detailing LockBit’s TTPs and bug bounty program.
- [56] Group-IB. Deciphering the Brain Cipher ransomware. <https://www.group-ib.com/blog/brain-cipher-ransomware/>, 2024. Analysis of the Brain Cipher variant and its code similarities to LockBit.
- [57] Netskope. BlackCat ransomware: Tactics and techniques from a targeted attack. <https://www.netskope.com/blog/blackcat-ransomware-tactics-and-techniques-from-a-targeted-attack>, 2024. Case study of a targeted BlackCat intrusion and lateral movement.
- [58] Viettel Cyber Security. Viettel releases cybersecurity report for the first half of 2024. <https://viettel.com.vn/en/news-events/news/viettel-releases-cybersecurity-report-for-the-first-half-of-2024/>, 2024. Comprehensive report on the threat landscape, highlighting VPN vulnerabilities.
- [59] Cohen, Stav and others. Here comes the AI Worm: Unleashing zero-click worms that target GenAI-powered applications. <https://arxiv.org/html/2403.02817v2>, 2024. Research paper proposing “Morris-II,” a theoretical worm targeting Generative AI ecosystems.
- [60] IBM Security. Cost of a data breach report 2024, 2024.
- [61] Gartner. Top strategic cybersecurity trends for 2024-2025, 2024.
- [62] Paul Cichonski, Tom Millar, Tim Grance, and Karen Scarfone. Computer security incident handling guide. Technical Report NIST SP 800-61 Revision 2, National Institute of Standards and Technology, 2012.
- [63] Fortinet. History of cyber warfare and the top 5 most notorious attacks. <https://www.fortinet.com/resources/cyberglossary/most-notorious-attacks-in-the-history-of-cyber-warfare>, 2024.